Code Quality & Static Analysis

Building Reliable, Secure, and Maintainable Software

Code Quality | SonarCloud | Code Smells & Bugs | Coverage Reports

1

Introduction to Code Quality

What makes code "high quality"?

Readability

Clear, self-documenting code

Reliability

Handles edge cases & errors

Security

Protected against threats

Performance

Efficient resource usage

Maintainability

Easy to change & extend

Testability

Verified by automated tests

Technical debt costs 23-40% of development time. Quality code saves time in the long run.

2

SonarCloud & SonarLint

SonarLint

In your IDE

- → Real-time feedback as you type
- → IDE plugins for VS Code, IntelliJ, Eclipse
- → Detects issues before commit
- → Works offline — no server needed
- → Supports 20+ languages

SonarCloud

In your CI/CD Pipeline

- → Cloud-based continuous analysis
- → Integrates with GitHub, GitLab, Azure DevOps
- → Pull Request decoration & quality gates
- → Team dashboards & trend tracking
- → Free for public repos

⟷ Together they form a continuous quality feedback loop

3

Code Smells, Bugs & Vulnerabilities

⚠️ Code Smells

Maintainability

- Long methods (> 30 lines)
- Duplicated code blocks
- Too many parameters
- Magic numbers without constants

```
if (x > 7 && y < 42)  // What do 7 and 42 mean?
```

🐛 Bugs

Reliability

- Null pointer dereferences
- Resource leaks
- Off-by-one errors
- Race conditions in threads

```
String s = null;
s.length(); // NullPointerException!
```

🔒 Vulnerabilities

Security

- SQL injection risks
- Hardcoded passwords
- Weak cryptography
- Insecure deserialization

```
query = "SELECT * FROM users WHERE id=" + userId; // SQL Injection!
```

4

Code Coverage Reports

Code coverage measures what % of your code is exercised by automated tests.

85%	72%	91%	88%
Line Coverage	**Branch Coverage**	**Function Coverage**	**Statement Coverage**
Lines executed	if/else paths	Methods called	All statements

Quality Gate Thresholds

< 50%	50–79%	80%+	90%+
🔴 Fail	🟡 Warning	🟢 Pass	⭐ Excellent

Coverage alone doesn't guarantee quality — focus on testing meaningful scenarios, not just hitting numbers.

5

Key Takeaways

01 Code quality is about readability, reliability, and security — not just working code.

02 SonarLint catches issues in real-time; SonarCloud enforces quality across the whole team.

03 Code smells, bugs, and vulnerabilities all need different remediation strategies.

04 Aim for 80%+ meaningful test coverage, and use quality gates to enforce it in CI/CD.

Start today: Install SonarLint in your IDE → sonarcloud.io

6